# 附錄一、數位身分驗證機制三階段要求說明

一、數位身分驗證機制之身分登錄階段及信物管理階段

應依下列定義進行信賴等級(LoA)評估，評估結果取身分登錄及信物管理兩階段最低之結果得出整體綜合性之信賴等級，並留存「數位身分驗證機制之信賴等級評估報告」(表例參考請詳附錄二)。另常見安全設計評分範例，請詳附錄三。

(一)身分登錄階段

1. 最低保證等級(Level 1)

   申請人自我宣稱或證實所提具之身分資訊具唯一性可辨識唯一身分，且申請人有簽署服務條款以表示理解與同意。

2. 低保證等級(Level 2)

   (1) 滿足 Level 1 之要求。

   (2) 足以表示其身分客觀存在：申請人提示可靠來源之資料，本身信賴等級應達 LoA2 或經政府機關核准之身分證明文件，且該資料已由申請人向信任機構進行註冊，並可透過公開且客觀方式檢驗資料正確性與有效性。

3. 中保證等級(Level 3)

   (1) 滿足 Level 2 之要求。

   (2) 由申請人提示一個經可靠來源之資料，本身信賴等級應達 LoA3 或經政府機關核准之身分證明文件，並經信任機構驗證。

4. 高保證等級(Level 4)

   (1) 滿足 Level 3 之要求。

   (2) 申請人提示兩個不同可靠來源之資料，其一應經信任機構驗證（本身信賴等級皆應達 LoA3 或經政府機關核准之身分證明文件)，其二做為其一資料身分之補強（本身信賴等級至少為 LoA2 或經政府機關核准之身分證明文件，或原開戶時之留存印鑑，或原開戶時之留存簽名)。

   (3) 若為法人臨櫃辦理帳戶，應以書面同意由其指定人員申請，經核驗後辦理。書面同意例如，蓋有公司名稱之簽名章及負責人印鑑或簽名。

   (4) 若為內政部核發之硬體自然人憑證或經濟部核發之工商憑證 IC 卡(正卡)，基於信賴其權威性與合法性，可不再提示第二可靠來源資料做為補強。

5. 最高保證等級(Level 5)

   (1) 滿足 Level 4 之要求。

   (2) 須經人工查驗（如臨櫃辦理、VTM)。

(二)信物管理階段

1. 最低保證等級(Level 1)
   (1) 信物有制定作業安全政策及作業程序(如啟用、綁定、保存、更換及撤銷等)。
   (2) 信物須由申請人或經信物服務提供單位授權之人員啟用。
2. 低保證等級(Level 2)
   (1) 滿足 Level 1 之要求。
   (2) 信物必須加密保護，如對稱式或非對稱式之加密保護。
   (3) 信物必須親自交付或檢查交付方式與該申請人合理關聯。
3. 中保證等級(Level 3)
   (1) 滿足 Level 2 之要求。
   (2) 信物啟用時須驗證個體和信物關聯性。
   (3) 信物具防竄改或防資料外洩之保護措施(如數位簽章或存於硬體載具但設定為鎖定狀態)。
   (4) 若信物因效期需進行更換或展期者,依身分登錄進行身分核驗。
4. 高保證等級(Level 4)
   (1) 滿足 Level 3 之要求
   (2) 保存信物之硬體設備且具備竄改檢測機制，如符合 FIPS 140-2 Level 2 或其他相同安全強度之認證。
   (3) 若使用 TEE、安全載具、行動裝置做為信物，應符合 Global Platform 標準或其他相同安全強度之認證，或具備資料管控、破壞偵測、自我測試等防護機制;行動裝置應用程式須依「行動裝置應用程式作業規範」具備防入侵、執行期間保護及機敏資料防護機制，以確保安全性與防竄改能力。
   (4) 若信物作業程序包含更換或展期，依身分登錄進行身分核驗。
   (5) 若信物作業程序包含啟用，只允許在指定時間內完成。
   (6) 若信物作業程序包含信物簽收及保存，須經申請人或其授權代理人同意。
5. 最高保證等級(Level 5)
   (1) 滿足 Level 4 之要求。
   (2) 必須採用防竄改之硬體裝置保存信物，以防被非法匯出或複製且具竄改檢測機制及自動銷毀刪除機制，如符合 FIPS 140-2 Level 3 或其他相同安全強度之認證。
   (3) 應具「電子簽章法」之不可否認性，亦即能確認簽署人身分，確保簽署意願，並透過私鑰簽署、時間戳與完整性驗證，防止否認或篡改，以推定為本人親自簽名或蓋章。
   (4) 信物更換或展期依身分登錄進行身分核驗。

二、數位身分驗證機制之身分驗證階段

應考量各項安全設計身分驗證過程中可能所遇之作業活動風險，並採取適當措施進行控管，除評估可能所遇之作業活動風險外，亦可參考常見安全設計身分驗證階段要求(詳參附錄五)，另金融機構應自行評估並留意可能之作業活動風險，如：

1. 線上破解：透過不斷猜測信物值的方式，並重複嘗試登入系統，以獲取真正的信物值
2. 線下破解：利用身分驗證過程以外的分析技術，獲取與信物產製相關的機密資訊。
3. 信物複製：客戶持有的信物或產製信物的方式遭非法複製。
4. 釣魚攻擊：攻擊者誘使個體與偽冒的驗證者互動，進而竊取足以偽冒該個體之機敏資料。
5. 竊聽攻擊：攻擊者監聽客戶身分驗證作業之過程，以獲取關鍵訊息，並在後續的主動攻擊中冒充該客戶。
6. 重送攻擊：攻擊者攔截並重送客戶與金融機構之間正常往來的驗證資訊，藉此冒充客戶進行身分驗證。
7. 連線劫持：當客戶與金融機構完成身分驗證並開始交換訊息後，攻擊者介入兩者之間的通信管道，進而冒充客戶或金融機構，攔截並控制會話資料交換。
8. 中間人攻擊：攻擊者介入客戶與金融機構之間，攔截並篡改身分驗證資訊，並同時冒充客戶與金融機構，與雙方分別互動，以便利用一方傳送的驗證訊息成功欺騙另一方。
9. 信物竊取：攻擊者竊取用於產製或儲存信物的裝置。
10. 欺騙偽裝攻擊：攻擊者冒充另一客戶，以執行其原本無法完成的行為。